dreamDEX Perps Builder Bounty — reproducible testnet findings

I tested the dreamDEX perps testnet as an outside builder: REST API, WebSocket feed, the deployed app, the public bot kit and the perps contracts on chain 50312. This report collects 39 independently reproducible issues (4 major, 35 normal). Every item lives in its own Markdown file under feedback/, following the bounty template. The security-critical item did not go into the repository — I sent it privately to security@dreamdex.io as the rules require. Generated 2026-10-19 13:36 UTC.

How I worked

Each claim went through the same loop: reproduce it fresh against the live testnet (twice where noted), compare against the published docs and OpenAPI spec, and drop anything that did not survive a control test. Nine candidate findings from my own fuzz lanes were killed during triage — falsified claims, duplicates of earlier files, and by-design behavior all went in the bin rather than into this report. Rate-limit, CORS and auth batteries ran in two independent passes with full request/response logs.

Highlights

06 / 07 / 13 (major): the WebSocket feed rejects every documented subscribe form; the REST-over-WS surface ignores the bearer it demands; and the app documentation points at chain 50383 while the live API serves only 50312. **31 (major):** crafted numeric input turns into 500/503 responses that leak the exact viem version, the internal markets-sdk package and RPC call names. **18:** the prepare endpoints hand back signable calldata for orders the chain then rejects with IncorrectOrder(). **25:** the docs market table lists six markets that exist nowhere on this testnet. **26:** every visitor gets redirected to a default market that returns 404.

Major findings

#	Severity	Area	Title
6	major	API	Every documented WebSocket subscribe channel fails with subscription_failed on testnet
7	major	API	Authenticated REST-over-WebSocket requests never carry the documented bearerToken — 401 for every valid token
13	major	docs	Perps developer page documents chain 50383 (Hideki) contract addresses that have no code on the chain the perps API actually runs (50312)
31	major	API	Numeric overflows 500/503 leak viem version, markets-sdk package, RPC method

Normal findings

#	Severity	Area	Title
2	normal	app	Public storage bucket listing enabled on cdn.dreamdex.io
3	normal	app	CSP report-only header on app.testnet responses discloses internal dev/staging hosts
4	normal	API	Unauthenticated /metrics on api.testnet.dreamdex.io exposes internal route table and traffic stats
5	normal	API	State-changing POST /api/sponsor/warm accepts unauthenticated calls without rate limiting
8	normal	API	Subscribe replies subscribed and then subscription_failed for the same frame (contradictory protocol responses)
9	normal	docs	Market Data docs promise unknown symbols are silently skipped (empty []), live API returns 400 invalid_param
10	normal	docs	Market Data docs show comma-separated symbols returning [], live API parses both symbols (200 with data)
11	normal	API	WS operations with missing parameters return a REST-style 404 bad_request envelope instead of the documented invalid_parameters protocol error
12	normal	docs	Error Handling table documents error name invalid_interval, live API returns invalid_param for the same case
14	normal	docs	Trader docs list 21 markets as BTC-PERP style names; the testnet API serves 24 perps under BASE:USDso and 404s every documented name
15	normal	docs	HTTP API base-URL table sends testnet developers to stg.api.dreamdex.io while the perps testnet host api.testnet.dreamdex.io is undocumented anywhere
16	normal	API	NUL byte in the URL path returns 400 with empty body and no Error-Name header, violating the documented JSON error contract

#	Severity	Area	Title
17	normal	API	POST /v0/auth/login with a non-JSON Content-Type returns 500 internal_error and leaks a V8 exception string
18	normal	API	Cancel/reduce prepares return calldata for nonexistent order ids
19	normal	API	Leverage above documented per-market maximum accepted, amount minimum enforced
20	normal	contracts	9 of 24 pools have no stop-order registry while docs advertise TP/SL
21	normal	contracts	Three pools outside the insurance-fund tier while docs present that stage
22	normal	contracts	Voucher campaign over, budget 0, claim() reverts while docs promise a claimable credit
23	normal	contracts	One EOA owns every core perps contract and the shared pool beacon
24	normal	contracts	No perps contract has published source on the explorer
25	normal	docs	Docs table lists six perps markets that do not exist on the testnet
26	normal	app	App 307s visitors to STT:USDso; API 404 market_not_found
27	normal	app	App offers 10m candles; API/spec enum accepts only 1m|5m|15m|1h|4h|1d
28	normal	SDK	Bot kit default USDC.e:USDso not in live spot registry
29	normal	API	stg and api.testnet WS hosts answer same malformed frame with different validators
30	normal	docs	WS feed published as /v0/ws, /v0/ws/public and dead /v0/ws/ (404)
32	normal	API	5MB body accepted, 500 instead of 413, 10MB echo
33	normal	API	Unsupported method on known routes returns 404 bad_request, not 405
34	normal	API	PATCH missing body without Content-Type reports invalid_amount, not invalid_request_body
35	normal	API	Duplicate JSON keys accepted last-key-wins and produce calldata
36	normal	API	limit accepts 0x10/1e3; unknown/negative query params silently ignored
37	normal	API	Unknown-route 404 uses undocumented bad_request name and omits Error-Name header
38	normal	API	Margin deposit ignores currency while vault rejects same values
39	normal	API	Rate limit trips only at ~175 RPS; every 429 has Retry-After: 1
40	normal	API	Gzipped body rejected as invalid JSON instead of 415

Reproduction

Each feedback file is self-contained: steps, expected, actual, evidence and environment. Nothing needs our private infrastructure — plain curl against the public testnet endpoints, or the public repository and RPC where a contract item is involved. The repository README carries the same index.